统一权限管理系统
需求与详细设计说明书

版本 3.0.0

2026 年 11 月 12 日

目录

1 引言 4
1.1 编写目的 4
1.2 项目背景 4
1.3 定义 4
1.4 参考资料 5
2 任务概述 6
2.1 目标与功能范围 6
2.2 运行环境 6
2.3 条件与业务约束 6
2.4 初始化 7
3 数据描述 8
3.1 概念模型 8
3.2 数据与处理边界 8
3.3 关系模型 9
3.4 数据字典 10
3.4.1 department 部门 10
3.4.2 app_user 用户 10
3.4.3 role 角色 10
3.4.4 business_system 业务系统 11
3.4.5 permission 权限 11
3.4.6 user_role 用户角色关联 11
3.4.7 role_permission 角色权限关联 11
3.5 索引与完整性 12
3.6 事务与删除规则 12
4 功能需求 13
4.1 功能划分 13
4.2 功能描述 14
4.2.1 登录 14
4.2.2 查看当前用户与退出 16
4.2.3 用户维护 17
4.2.4 部门维护 18
4.2.5 业务系统维护 19
4.2.6 操作权限维护 20
4.2.7 角色维护与权限配置 21
4.2.8 分配用户角色 22
4.2.9 撤销用户角色 24
4.2.10 当前操作鉴权 25
4.3 两套架构设计 26
4.3.1 结构化设计 26
4.3.2 DDD 设计 28
4.3.3 共同契约与配置装配 30

4.3.4 登录与会话详细设计 31
4.3.5 角色分配详细设计 33
4.3.6 当前权限判断 35
4.3.7 对象拷贝与运行日志 35
4.4 接口与输入设计 36
4.4.1 公共约定 36
4.4.2 认证与鉴权接口 37
4.4.3 基础数据与授权接口 38
4.4.4 错误与异常映射 39
5 性能需求 40
5.1 数据精确度 40
5.2 时间特性 40
5.3 适应性 40
6 运行需求 41
6.1 软件接口与部署 41
6.2 构建与启动 41
6.3 故障处理 42
6.4 图文与构建产物 42
7 其它需求 43
7.1 可用性 43
7.2 权限隔离与安全 43
7.3 功能验收 43
7.4 文档与模型验收 44

1 引言

1.1 编写目的

本文规定统一权限管理系统的需求、数据模型、接口、两套服务设计和验收条件，供课程评审、开发及测试使用。系统以 RBAC 为授权模型，通过配置选择结构化或 DDD 服务实现。

本文为重做后的设计基线，版本为 3.0.0。文档沿用原说明书的七章结构、用例表和图表组织方式，业务内容按第一轮检查意见及本次确认结果重新设计。设计中的接口与类是待实现规格，验收结果由实现阶段的测试报告记录。

1.2 项目背景

多个业务系统需要共同维护用户、角色和权限。平台集中保存用户账号、部门、业务系统及权限目录，为客户端提供登录和当前权限判断。管理用户通过后台维护基础数据并配置授权；业务系统根据鉴权结果决定是否执行自己的业务操作。

平台以用户、角色和权限的两组多对多关系表达授权。部门限定角色归属和管理员的数据范围，业务系统限定权限命名空间。权限管理后台也登记为业务系统，使用相同的授权规则。

1.3 定义

术语	定义
用户	员工与登录账号的统一实体，具有用户名、姓名、手机号和部门归属。
部门	具有父子关系的组织节点，可包含直接成员和下级部门。
角色	属于一个部门的权限集合，可分配给多个用户。
权限	业务系统内可检查的一项操作，由系统标识和权限编码共同定位。
认证	按用户名查找用户，验证输入的手机号与账号资料一致。
授权与鉴权	授权建立用户角色和角色权限关系；鉴权读取当前关系判断操作是否允许。
RBAC	用户通过角色取得权限，多个角色的权限取并集。
管理用户	拥有管理操作权限的用户；其身份由角色权限表达。
Session	服务器保存的登录身份；业务身份包含用户编号和本次目标系统标识。
Service Port	共享用例接口、输入输出及持久化端口的代码契约。
结构化实现	按老师示例采用分层事务脚本，Service 集中编排业务步骤。

术语	定义
DDD 实现	应用服务编排用例，领域对象维护业务规则和聚合内一致性。
CloneFactory	老师提供的编译期对象拷贝工具，生成边界数据转换代码。

1.4 参考资料

资料	使用范围
《5. 面向对象设计》	类图、包图、顺序图、对象职责及 DDD 分层；重点为第 3、6–29、49–52、60–64、131–142 页。
旧版需求与详细设计说明书 v2	封面、目录、七章结构、用例表及图表排版。
老师的课程管理示例	共享 API 与端口、双实现及配置装配。查阅 master 的 fde08d5。
老师的基础示例与 CloneFactory	注解处理器、对象转换及近期教学写法。查阅 master 的 854d0e0。
外部系统 API 示例	用户名、password 和 systems 的输入命名参考。
UML 2.5.1 与 StarUML 官方文档	UML 元素和关系表示。
Chen 原论文节选 与 数据库课程 ER 建模讲义	陈氏实体、联系、属性及参与约束。

2 任务概述

2.1 目标与功能范围

系统完成用户、部门、业务系统、权限和角色的单项维护，用户角色分配与撤销，角色权限配置，以及登录、退出和当前权限查询。两套服务实现共用 API 和数据库，通过启动配置选用其中一套。

本版范围排除审计、批量操作、导入导出、部门调动、公司实体、角色模板、OAuth/OIDC 和跨系统免登录。运行日志使用 Logback 输出。

2.2 运行环境

管理后台与业务系统演示客户端使用桌面浏览器，后端以单个 Spring Boot 应用运行，持久化使用 MySQL 8.4 LTS 和 InnoDB。演示采用同源反向代理，客户端通过相同站点路径访问平台 API 并携带 Cookie。

Java 采用 21 LTS，框架依赖在实现时按官方受支持稳定版本及 CloneFactory 兼容性锁定。已查阅的老师示例使用 Spring Boot 4.1.2；依赖清单由实际构建核验后写入 POM。

2.3 条件与业务约束

编号	约束
BR-01	授权来源为 user_role 与 role_permission；用户无角色或无匹配权限时拒绝操作。
BR-02	一个用户可持有多个角色，角色权限取并集；角色可包含多个业务系统的权限。
BR-03	每个角色必须属于一个部门；分配角色时，操作者、目标用户和角色属于同一非空部门。
BR-04	管理用户资料和角色时校验本部门边界；部门树、系统及权限目录由相应管理权限控制。
BR-05	用户名全局唯一；角色名在部门内唯一；权限编码在系统内唯一；系统标识全局唯一。
BR-06	用户主键由数据库生成；普通资料修改使用字段白名单，部门归属在创建时确定。
BR-07	删除用户时同事务清理用户角色关联；其他实体有引用时返回冲突，先处理关联再删除。
BR-08	登录凭据为用户名和手机号，password 字段承载手机号，systems 数组只接受一个目标系统。

编号	约束
BR-09	成功登录要求拥有目标系统的 login 权限；后续请求按当前授权关系检查。
BR-10	Session 保存业务身份；敏感写操作经过会话、CSRF、操作权限和数据边界校验。
BR-11	结构化版和 DDD 版返回相同 HTTP 结果并保持相同数据库约束。

用户多部门归属和子部门管理范围尚待业务确认。本版分别按“用户至多属于一个部门”和“管理本部门直接成员”建模；未分配部门的用户可在获得系统登录权限后登录，部门管理操作要求非空部门。后续调整这两项决定时同步修订模型、接口和测试。

2.4 初始化

初始化登记平台自身的系统标识 rbac、各系统 login 权限以及后台操作权限；为演示部门创建角色，并通过 user_role 与 role_permission 关联首批管理用户。初始化脚本在空库部署时由开发者执行。

后台管理资格取决于实际权限集合。初始管理员与普通用户使用相同用户实体；角色名称用于展示。初始化检查每个管理角色的部门归属、用户归属以及权限关系，保证至少有一个账号能够完成课程演示所需的配置。

3 数据描述

3.1 概念模型

平台包含部门、用户、角色、权限和业务系统五类业务实体。部门与角色是一对多关系；用户与角色、角色与权限是多对多关系。业务系统拥有权限，部门具有递归父子关系。

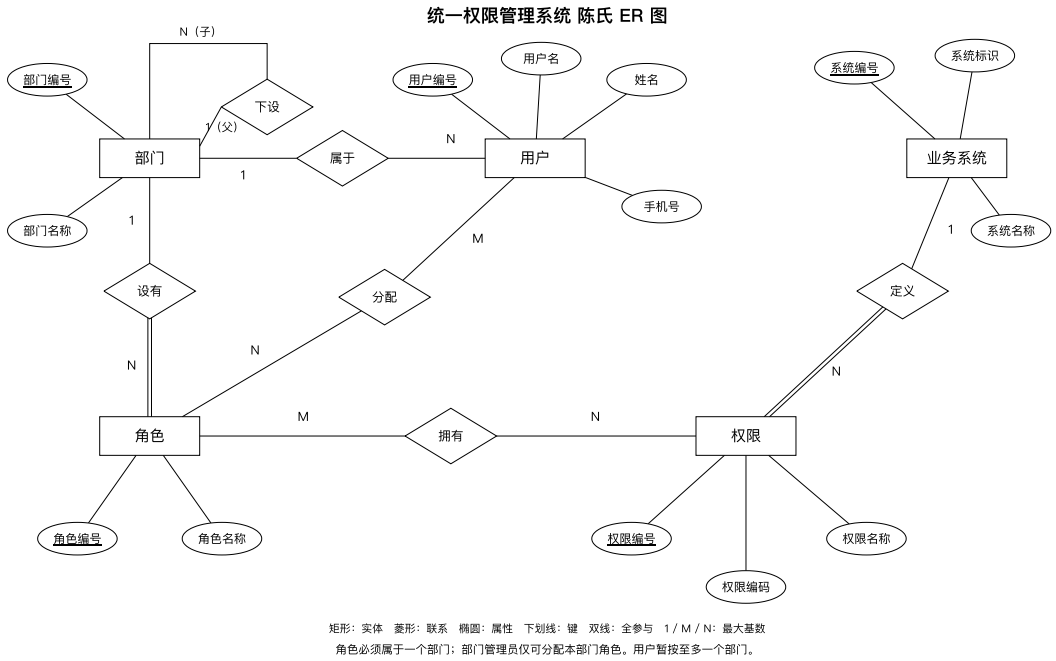


图 1. 统一权限管理系统 陈氏 ER 图

图中实体用矩形、联系用菱形、属性用椭圆，键属性加下划线。角色归属部门、权限归属系统采用全参与。陈氏图中的多对多联系在关系模型中转换为关联表。

3.2 数据与处理边界

处理	输入与输出	数据读写
身份认证	用户名、手机号、单个系统标识；返回登录身份	读取用户及 RBAC 关系，建立 Session。
基础数据维护	用户、部门、系统和权限资料；返回记录或处理结果	写入对应实体表，检查唯一性和引用关系。
授权配置	用户编号、角色编号、权限编号；返回授权关系	读用户与角色部门，写入或删除两张关联表。

处理	输入与输出	数据读写
运行时鉴权	当前身份、目标权限编码；返回允许或拒绝	按当前 user_role、role_permission、permission 和 business_system 查询。

客户端提交资料后由 Controller 校验格式并转换为 Command，服务执行业务规则，持久化端口读写数据库。返回数据经 Result 转换为 VO。业务系统保存和处理自己的业务记录，根据平台返回的权限结论执行受控操作。

3.3 关系模型



图 2. 统一权限管理系统 数据库表关系图

五张实体表使用 BIGINT 自增主键。两张关联表使用复合主键，以现有字段保证同一关联只保存一次。外键采用 RESTRICT，删除流程由服务明确安排。数据库结构定义见 sql/schema.sql。

3.4 数据字典

3.4.1 department 部门

字段	类型	可空	约束	含义
id	BIGINT	否	主键，自增	部门编号
name	VARCHAR(100)	否	非空文本	部门名称
parent_id	BIGINT	是	外键 department.id	根部门为空

3.4.2 app_user 用户

字段	类型	可空	约束	含义
id	BIGINT	否	主键，自增	用户编号
username	VARCHAR(64)	否	全局唯一	用户名，创建后固定
name	VARCHAR(100)	否	非空文本	姓名
phone	VARCHAR(20)	否	格式由 API 校验	手机号，承载本版登录凭据
department_id	BIGINT	是	外键 department.id	用户所属部门

3.4.3 role 角色

字段	类型	可空	约束	含义
id	BIGINT	否	主键，自增	角色编号
name	VARCHAR(100)	否	部门内唯一	角色名称
department_id	BIGINT	否	外键 department.id	角色归属部门

3.4.4 business_system 业务系统

字段	类型	可空	约束	含义
id	BIGINT	否	主键，自增	系统编号
system_key	VARCHAR(64)	否	全局唯一	系统标识，创建后固定
name	VARCHAR(100)	否	非空文本	系统名称

3.4.5 permission 权限

字段	类型	可空	约束	含义
id	BIGINT	否	主键，自增	权限编号
system_id	BIGINT	否	外键 business_system.id	所属系统，创建后固定
code	VARCHAR(100)	否	系统内唯一	权限编码，创建后固定
name	VARCHAR(100)	否	非空文本	权限名称

3.4.6 user_role 用户角色关联

字段	类型	可空	约束	含义
user_id	BIGINT	否	复合主键，外键 app_user.id	被授权用户
role_id	BIGINT	否	复合主键，外键 role.id	分配的角色

3.4.7 role_permission 角色权限关联

字段	类型	可空	约束	含义
role_id	BIGINT	否	复合主键，外键 role.id	持有权限的角色
permission_id	BIGINT	否	复合主键，外键 permission.id	被授予权限

3.5 索引与完整性

索引或约束	用途
app_user.username 唯一索引	按用户名认证并阻止重复账号。
role(department_id, name) 唯一索引	部门内角色重名检查。
business_system.system_key 唯一索引	按目标系统定位权限目录。
permission(system_id, code) 唯一索引	定位系统中的操作权限。
user_role(user_id, role_id) 复合主键	读取用户角色并防止重复分配；role_id 单列索引用于角色引用检查。
role_permission(role_id, permission_id) 复合主键	读取角色权限并防止重复配置；permission_id 索引用于权限引用检查。
department.parent_id、app_user.department_id 索引	查询子部门和本部门用户。

主外键保证引用完整性。部门成环、同部门分配及字段业务格式由服务和 Controller 校验。多角色鉴权以 EXISTS 查询匹配关系，返回布尔结果，避免连接重复导致误判。

3.6 事务与删除规则

角色分配、撤销、角色权限变更和用户删除均为服务级事务。分配时先检查操作权限，再读取用户和角色，检查部门与重复关系，最后写入关联表。数据库复合主键处理并发重复插入；服务将唯一约束冲突映射为 409。

删除用户先删除 user_role，再删除 app_user，任一步失败均回滚。删除部门检查子部门、用户和角色；删除角色检查用户角色与角色权限；删除权限检查角色权限；删除系统检查权限。存在引用时返回 409。

本版使用数据库事务、外键和唯一约束处理一致性，实体不增加版本字段或手工乐观锁协议。用户名、系统标识、权限编码和部门归属使用固定字段规则，减少维护时改变授权语义的入口。

4 功能需求

4.1 功能划分

模块	操作权限	功能
认证与会话	目标系统 login	登录、当前用户、退出、CSRF 凭据。
用户管理	user.view / user.create / user.edit / user.delete	本部门用户查询、新建、资料修改、删除。
部门管理	department.manage	部门树查询、新建、改名、删除。
系统管理	system.manage	系统登记、查询、改名、删除。
权限管理	permission.manage	系统权限查询、新建、改名、删除。
角色管理	role.manage	本部门角色维护和角色权限配置。
用户角色	user.role.assign	本部门用户角色分配与撤销。
当前鉴权	目标系统 login 及被查询操作	查询当前用户是否具有该操作权限。

管理 API 的权限属于 rbac 系统。拥有 user.role.assign 的用户可分配现有角色；角色权限编辑要求 role.manage。单独取得角色分配权限的用户无法修改角色的权限集合。

4.2 功能描述

4.2.1 登录

用例编号： UPMS-AUTH-001	用例名称： 登录
级别： 用户目标	
包： 身份认证与会话	
参与者： 用户及业务系统客户端	
描述： 用户提交登录资料，经账号匹配与 RBAC 登录权限检查后建立会话。	
触发事件： 提交用户名、手机号与目标系统。	
前置条件： 系统已经登记，用户资料存在。	
主成功场景：	**信息**
1. 校验用户名、password 和 systems。	systems 只含一个非空系统标识。
2. 按用户名读取账号并匹配手机号。	凭据不匹配返回统一认证失败信息。
3. 查询目标系统 login 权限。	用户经角色取得该权限。
4. 更换会话标识并保存身份，返回登录结果。	Session 业务身份包含 userId 和 systemKey。
扩展场景：	**处理及信息**
参数缺失或格式错误	400，服务方法不执行。
用户不存在或手机号不匹配	401，清理已有登录身份。
目标系统不存在或无登录权限	403，不建立成功登录身份。
后置条件： 登录成功建立当前系统会话；失败保留统一错误响应。	

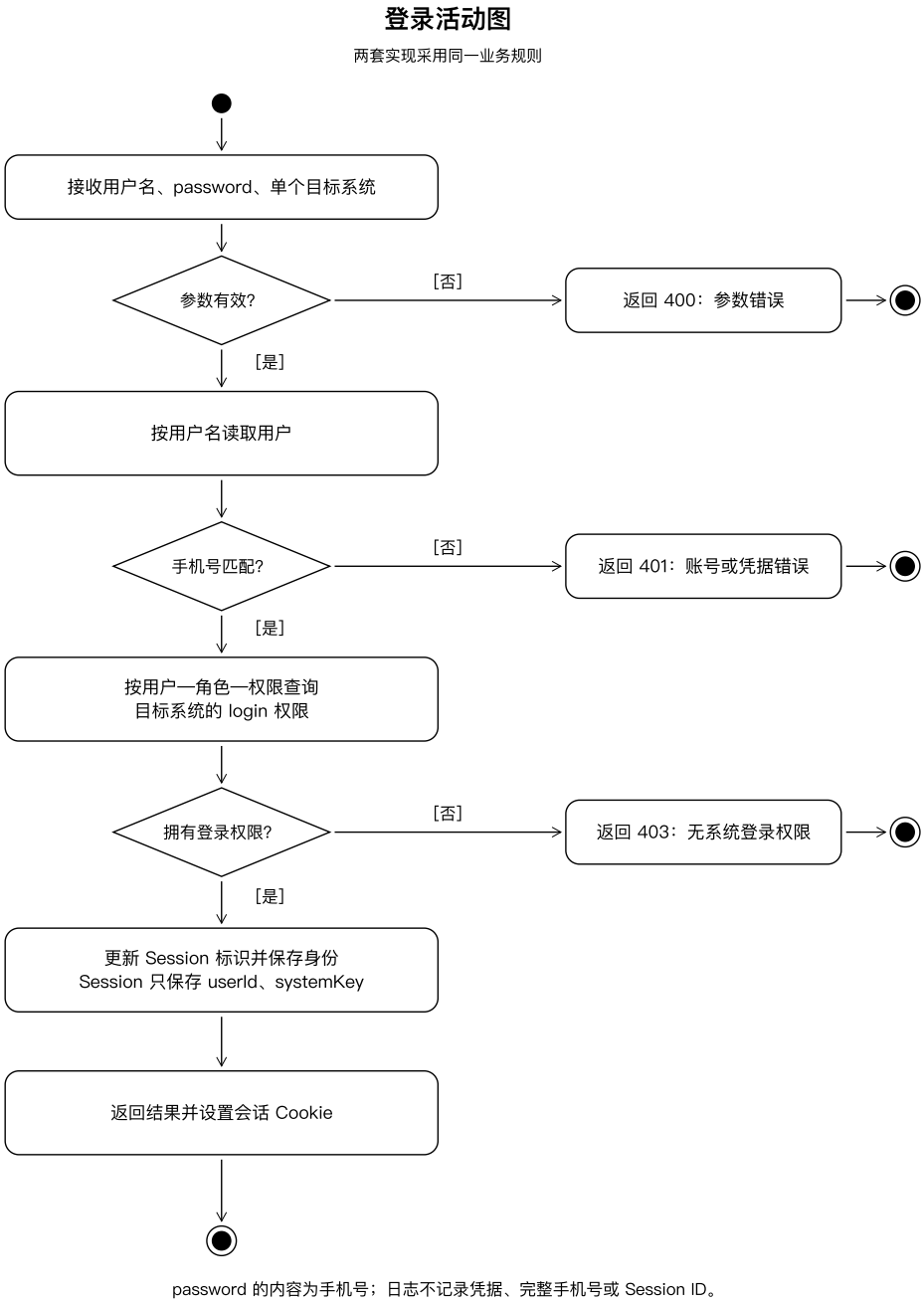


图 3. 登录 活动图

备注：password 字段承载手机号；系统登录资格通过角色的 login 权限取得。

图中处理／实际方法	调用说明 URL	功能
AuthController.csrf	GET /api/auth/csrf	取得写请求所需的 CSRF 凭据及请求头名称。
AuthController.login	POST /api/auth/login	校验用户名、手机号和目标系统登录权限，建立当前系统会话。

4.2.2 查看当前用户与退出

用例编号： UPMS-AUTH-002	用例名称： 查看当前用户与退出
级别： 用户目标	
包： 身份认证与会话	
参与者： 已登录用户	
描述： 用户查看当前身份，并在结束使用时退出当前会话。	
触发事件： 查询自己或退出当前会话。	
前置条件： Cookie 对应有效 Session。	
主成功场景：	**信息**
1. 按 Session 中的 userId 读取当前用户。	返回本人编号、用户名、姓名和部门。
2. 退出时销毁 Session 并清理会话 Cookie。	后续请求重新认证。
扩展场景：	**处理及信息**
会话缺失、过期或账号已删除	401。
CSRF 校验失败	退出写请求返回 403。
后置条件： 查询返回本人信息；退出后原会话失效。	

备注：退出接口校验 CSRF；会话已失效时重复退出仍返回 204。

图中处理／实际方法	调用说明 URL	功能
AuthController.me	GET /api/auth/me	读取当前登录用户的编号、用户名、姓名和部门。
AuthController.logout	POST /api/auth/logout	校验 CSRF 后销毁当前会话，重复退出返回成功。

4.2.3 用户维护

用例编号： UPMS-USER-001	用例名称： 用户维护
级别： 用户目标	
包： 用户管理	
参与者： 具有用户操作权限的管理用户	
描述： 管理用户维护本部门用户，普通用户修改本人允许编辑的资料。	
触发事件： 查询、新建、修改或删除本部门用户。	
前置条件： 操作者已登录 rbac 且有非空部门。	
主成功场景：	**信息**
1. 按操作检查 user.view、user.create、user.edit 或 user.delete。	列表按操作者部门过滤。
2. 新建用户填写用户名、姓名和手机号。	部门由操作者当前部门确定。
3. 修改资料只接受姓名和手机号。	用户名和编号固定。
4. 删除用户时清理其角色关联。	关联删除与用户删除在同一事务内完成。
扩展场景：	**处理及信息**
目标用户不属于本部门	403。
用户名重复	409。
目标不存在	404。
请求含受保护字段	400。
后置条件： 资料或删除结果持久化；删除用户后原会话的后续请求返回 401。	

备注：普通资料修改使用字段白名单，用户名、用户编号和部门归属保持固定。

图中处理／实际方法	调用说明 URL	功能
UserController.list / get	GET /api/users GET /api/users/{id}	按本部门范围查询用户列表及详情。
UserController.create / update / delete	POST /api/users PATCH /api/users/{id} DELETE /api/users/{id}	创建本部门用户、修改姓名及手机号，或删除用户及其角色关联。
AuthController.updateMe	PATCH /api/auth/me	修改本人姓名及手机号。

4.2.4 部门维护

用例编号： UPMS-DEPT-001	用例名称： 部门维护
级别： 用户目标	
包： 部门管理	
参与者： 具有 department.manage 的用户	
描述： 具有部门管理权限的用户维护部门树及部门名称。	
触发事件： 维护部门树。	
前置条件： 已登录 rbac。	
主成功场景：	**信息**
1. 查询部门树，或选择父部门新建节点。	根节点 parentId 为空。
2. 修改部门名称。	本版更新入口只接收 name。
3. 删除前检查子部门、用户和角色引用。	无引用时删除。
扩展场景：	**处理及信息**
父部门不存在	404。
名称为空或超过长度	400。
删除对象仍有引用	409。
后置条件： 部门层级和引用关系保持完整。	

备注：部门树表达组织层级；用户通过角色取得权限，部门不直接获得系统权限。

图中处理／实际方法	调用说明 URL	功能
DepartmentController.list / create	GET /api/departments POST /api/departments	查询部门树，或在指定父部门下创建部门。
DepartmentController.rename / delete	PATCH /api/departments/{id} DELETE /api/departments/{id}	修改部门名称；存在子部门、成员或角色时拒绝删除。

4.2.5 业务系统维护

用例编号： UPMS-SYS-001	用例名称： 业务系统维护
级别： 用户目标	
包： 业务系统管理	
参与者： 具有 system.manage 的用户	
描述： 具有系统管理权限的用户登记和维护业务系统目录。	
触发事件： 登记或维护业务系统。	
前置条件： 已登录 rbac。	
主成功场景：	**信息**
1. 登记 systemKey 和系统名称。	系统标识全局唯一。
2. 查询系统列表或修改名称。	系统标识创建后固定。
3. 删除前检查所属权限。	有权限定义时先处理权限。
扩展场景：	**处理及信息**
系统标识重复	409。
系统仍有权限	409。
对象不存在	404。
后置条件： 业务系统目录更新。	

备注：系统标识在创建后固定，权限使用该标识区分所属业务系统。

图中处理／实际方法	调用说明 URL	功能
SystemController.list / create	GET /api/systems POST /api/systems	查询及登记业务系统。
SystemController.rename / delete	PATCH /api/systems/{id} DELETE /api/systems/{id}	修改系统名称；存在权限引用时拒绝删除。

4.2.6 操作权限维护

用例编号： UPMS-PERM-001	用例名称： 操作权限维护
级别： 用户目标	
包： 权限目录管理	
参与者： 具有 permission.manage 的用户	
描述： 具有权限管理资格的用户维护系统内的操作权限目录。	
触发事件： 维护一个系统的权限目录。	
前置条件： 已登录 rbac，目标系统存在。	
主成功场景：	**信息**
1. 查询系统权限或创建 code、name。	系统内 code 唯一。
2. 修改权限名称。	系统归属和编码固定。
3. 删除前检查角色权限关联。	被引用时返回冲突。
扩展场景：	**处理及信息**
编码重复	409。
权限仍被角色引用	409。
系统或权限不存在	404。
后置条件： 权限目录更新，后续授权引用现有权限编号。	

备注：权限编码在所属系统内唯一；创建后只允许修改展示名称。

图中处理／实际方法	调用说明 URL	功能
PermissionController.list / create	GET /api/systems/{id}/permissions POST /api/systems/{id}/permissions	查询或登记指定系统内的权限。
PermissionController.rename / delete	PATCH /api/permissions/{id} DELETE /api/permissions/{id}	修改权限名称；存在角色权限引用时拒绝删除。

4.2.7 角色维护与权限配置

用例编号： UPMS-ROLE-001	用例名称： 角色维护与权限配置
级别： 用户目标	
包： 角色管理	
参与者： 具有 role.manage 的用户	
描述： 管理用户维护本部门角色，并逐项配置角色所持有的权限。	
触发事件： 维护本部门角色及其权限集合。	
前置条件： 已登录 rbac，操作者有非空部门。	
主成功场景：	**信息**
1. 创建或改名本部门角色。	创建时由操作者部门确定 role.department_id。
2. 查询权限目录，向角色授予或撤销现有权限。	校验角色属于本部门以及权限存在。
3. 删除角色前检查分配与权限关联。	先撤销关联再删除角色。
扩展场景：	**处理及信息**
角色不属于本部门	403。
部门内角色重名	409。
删除对象仍有引用	409。
权限不存在	404。
后置条件： 角色及权限集合更新；下一次鉴权读取当前关系。	

备注：角色归属一个部门，角色权限可涉及多个业务系统；授权由 role_permission 表保存。

图中处理／实际方法	调用说明 URL	功能
RoleController.list / get / create	GET /api/roles GET /api/roles/{id} POST /api/roles	查询本部门角色及详情，或创建本部门角色。
RoleController.rename / delete	PATCH /api/roles/{id} DELETE /api/roles/{id}	修改角色名称；存在用户或权限关联时拒绝删除。
RolePermissionController.list / grant / revoke	GET /api/roles/{id}/permissions PUT /api/roles/{id}/permissions/{permissionId} DELETE /api/roles/{id}/permissions/{permissionId}	读取、授予或撤销本部门角色的单项权限。

4.2.8 分配用户角色

用例编号： UPMS-GRANT-001	用例名称： 分配用户角色
级别： 用户目标	
包： 用户角色授权	
参与者： 具有 user.role.assign 的用户	
描述： 管理用户为本部门用户分配本部门角色。	
触发事件： 选择目标用户和角色。	
前置条件： 已登录 rbac，操作者有非空部门。	
主成功场景：	**信息**
1. 检查分配操作权限。	先通过 RBAC 确认操作者可执行分配。
2. 读取操作者、目标用户和角色。	三者均存在且属于同一非空部门。
3. 检查目标用户尚未持有该角色。	用户可以同时持有不同角色。
4. 事务内新增 user_role 并提交。	复合主键防止重复关系。
扩展场景：	**处理及信息**
无操作权限或超出部门范围	403，不写入。
用户或角色不存在	404。
已分配或并发重复插入	409。
后置条件： 角色分配持久化，目标用户下一次鉴权采用新权限集合。	

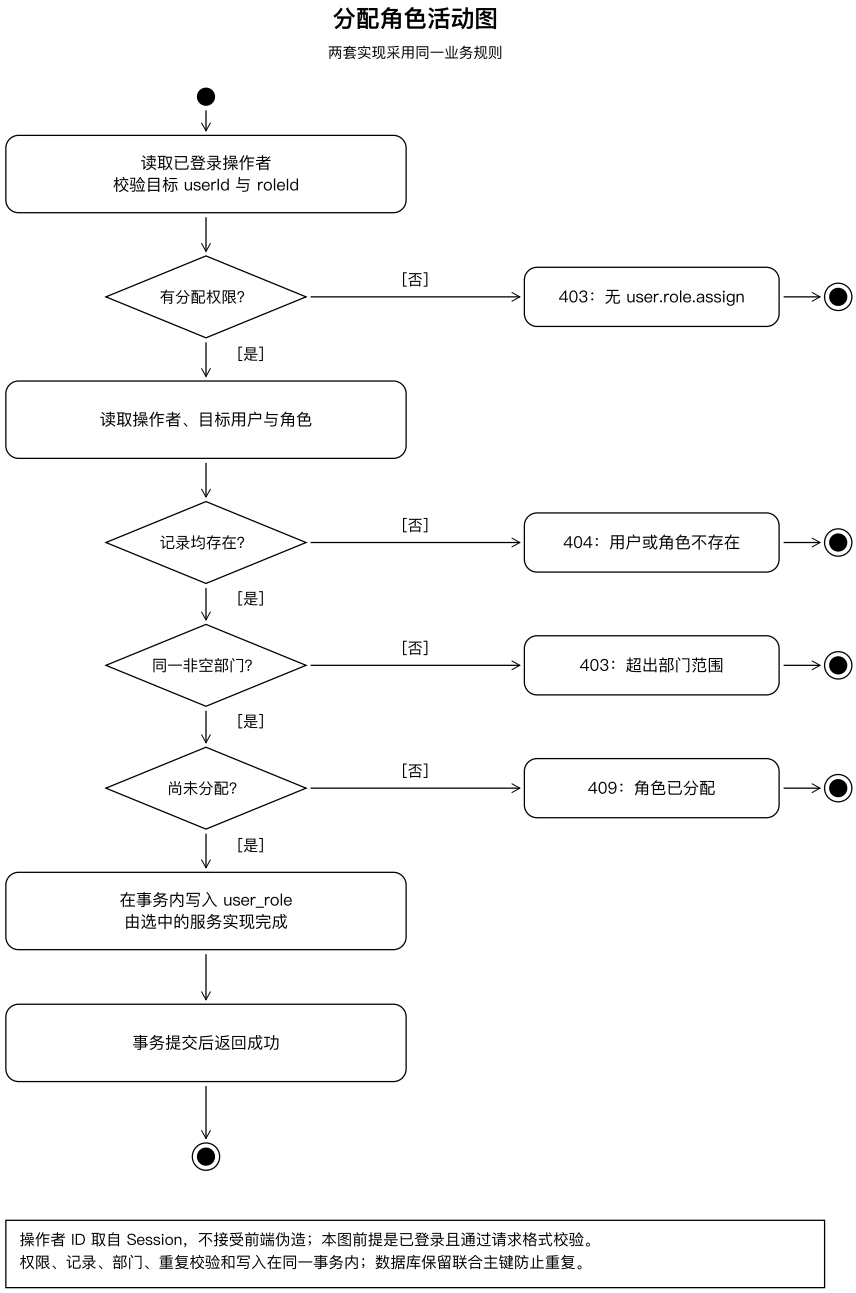


图 4. 分配用户角色 活动图

备注：操作者编号从服务端会话读取；操作者、目标用户和角色必须属于同一非空部门。

图中处理／实际方法	调用说明 URL	功能
UserRoleController.list	GET /api/users/{id}/roles	查询本部门用户已持有的角色。
UserRoleController.assign	POST /api/users/{id}/roles	校验操作权限与部门归属，新增一条用户角色关联。

4.2.9 撤销用户角色

用例编号： UPMS-GRANT-002	用例名称： 撤销用户角色
级别： 用户目标	
包： 用户角色授权	
参与者： 具有 user.role.assign 的用户	
描述： 管理用户撤销本部门用户已持有的一条角色关联。	
触发事件： 撤销一条用户角色关联。	
前置条件： 已登录 rbac，操作者与目标及角色同部门。	
主成功场景：	**信息**
1. 检查操作权限与部门边界。	沿用分配用例的范围规则。
2. 删除指定 user_role。	关联已不存在时仍返回成功。
扩展场景：	**处理及信息**
无权限或跨部门	403。
目标用户或角色不存在	404。
后置条件： 后续鉴权重新合并剩余角色的权限。	

备注：撤销后按其余角色合并权限；其他角色仍持有同一权限时，用户继续拥有该权限。

图中处理／实际方法	调用说明 URL	功能
UserRoleController.revoke	DELETE /api/users/{id}/roles/{roleId}	撤销本部门用户的一条角色关联，后续鉴权读取剩余角色。

4.2.10 当前操作鉴权

用例编号： UPMS-AUTHZ-001	用例名称： 当前操作鉴权
级别： 用户目标	
包： 运行时鉴权	
参与者： 已登录用户及业务系统客户端	
描述： 平台按当前用户的角色及角色权限关系，判断一项操作是否允许。	
触发事件： 检查当前用户的一项操作。	
前置条件： 当前 Session 有效，账号存在且仍有本系统 login 权限。	
主成功场景：	**信息**
1. 从 Session 取得用户编号和目标系统。	输入只包含待检查的权限编码。
2. 连接当前用户角色与角色权限关系。	匹配目标系统及编码。
3. 返回 allowed 布尔结果。	任一角色匹配即允许。
扩展场景：	**处理及信息**
会话失效或账号已删除	401。
本系统 login 权限被撤销	403。
编码不存在或未授予	200，allowed 为 false。
数据库不可用	503，业务系统拒绝执行受控操作。
后置条件： 返回本次查询结果。	

备注：目标系统取自 Session，客户端只提交权限编码；数据库不可用时拒绝受控操作。

图中处理／实际方法	调用说明 URL	功能
AuthorizationController.check	GET /api/auth/permissions/{code}	从会话取得用户和系统，查询当前 RBAC 关系并返回 allowed。

4.3 两套架构设计

4.3.1 结构化设计

结构化版采用 API、Service Port、事务脚本服务、Infrastructure 的分层。Controller 接收输入并读取当前身份；事务脚本依次检查操作权限、资源存在性、部门归属和重复关系，通过持久化端口完成修改。

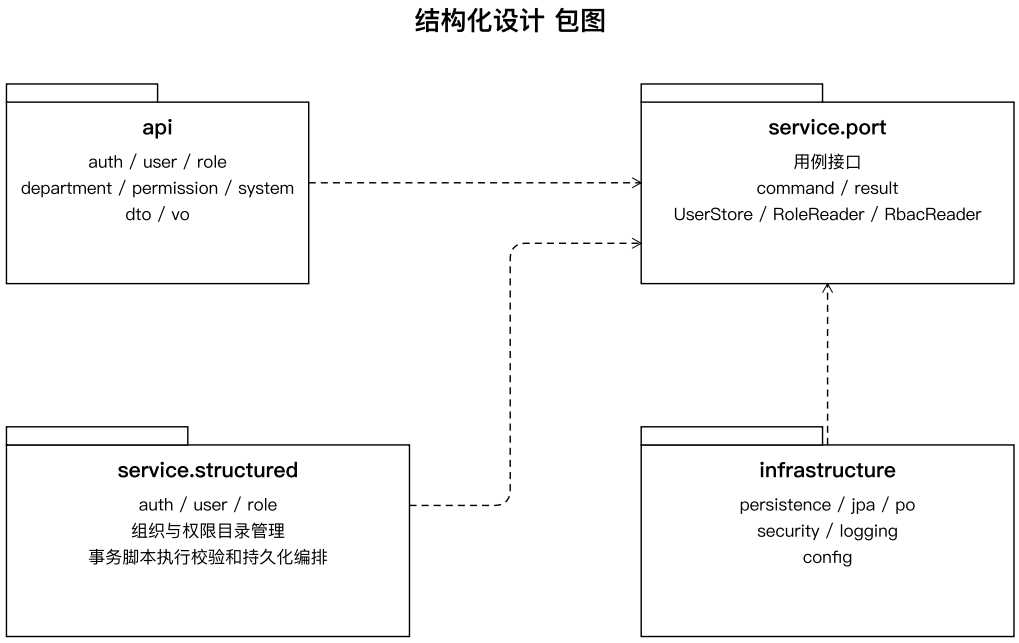


图 5. 结构化设计 包图

UserRoleUseCase 定义分配入口。StructuredUserRoleService 实现该接口，持有 UserStore、RoleReader 和 RbacReader。requireSameDepartment 与 requireUnassigned 为服务内部规则方法，分别检查部门和重复分配。

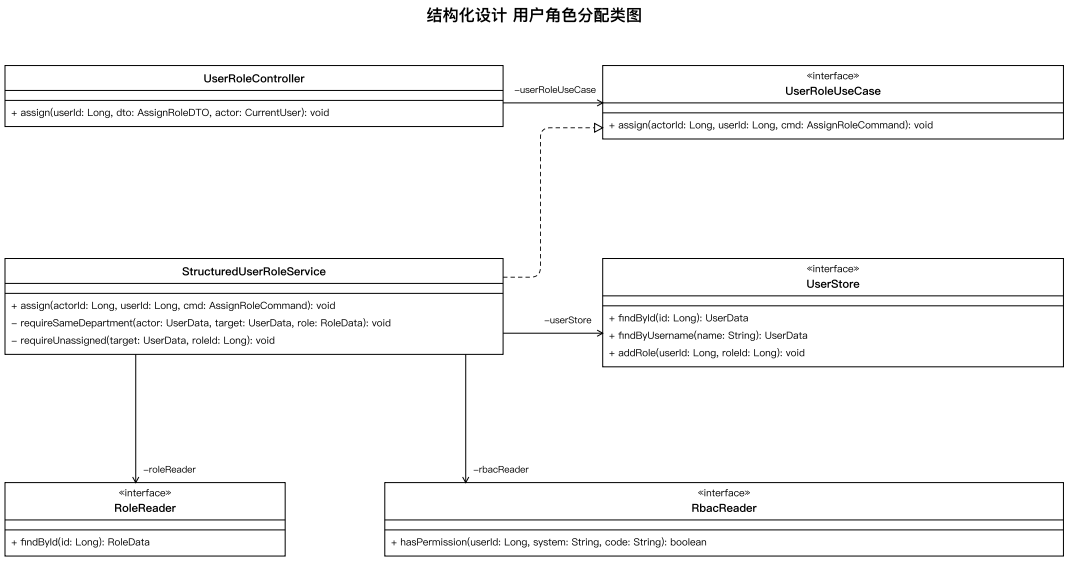


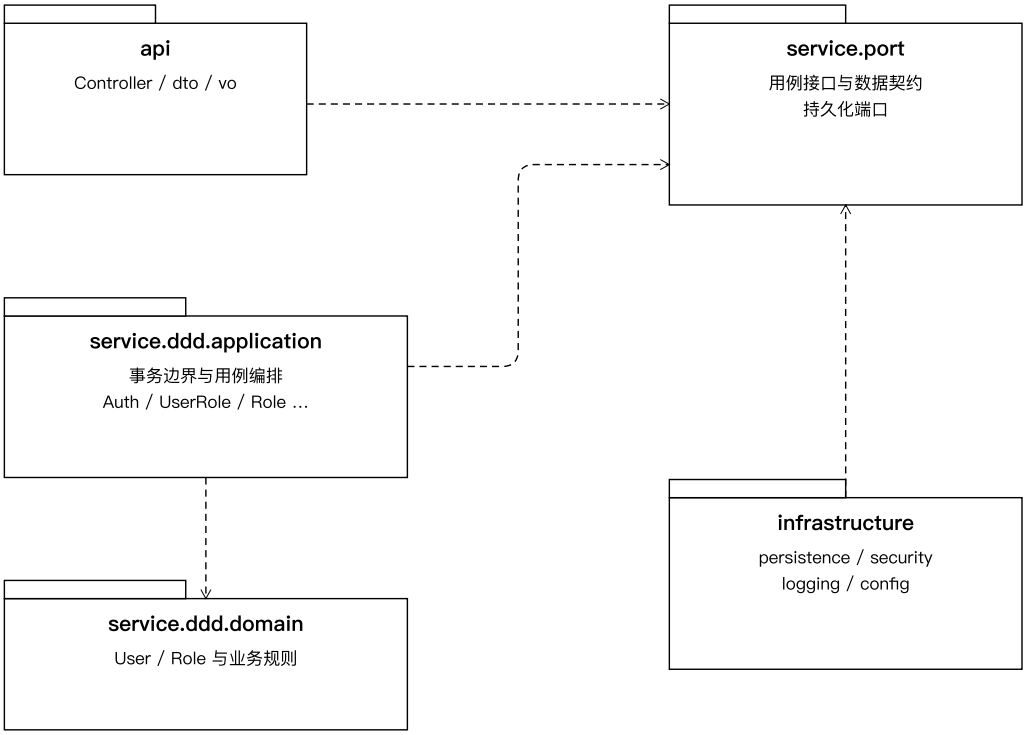
图 6. 结构化设计 用户角色分配类图

4.3.2 DDD 设计

DDD 版由 API、应用层、领域层和基础设施层组成。Service Port 提供共享契约。应用服务取得当前权限、加载数据、建立领域对象并开启事务；User 聚合管理已分配角色编号，assignRole 维护角色分配规则。

角色以编号和所属部门参与分配规则，聚合间使用编号引用。持久化适配器返回共享 UserData 和 RoleData；应用服务以其值构造领域对象，完成规则校验后通过端口新增关联记录。基础设施保持对领域对象的隔离。

DDD 设计 包图



领域层保持框架无关。配置选择 ddd 时装配应用服务，基础设施实现共享端口。

图 7. DDD 设计 包图

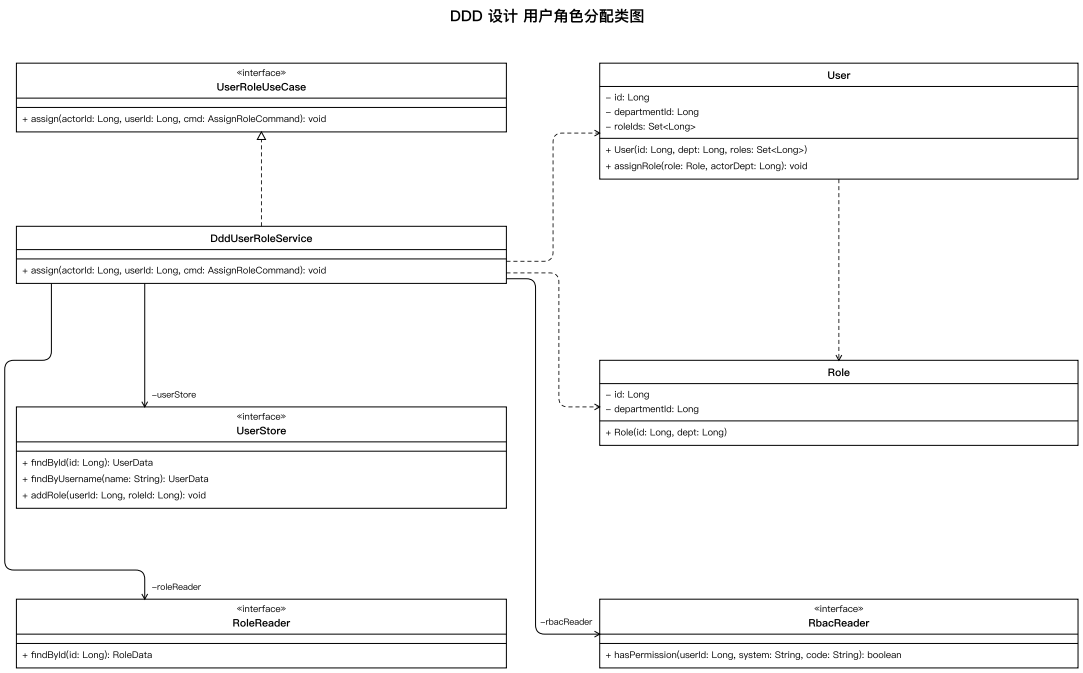


图 8. DDD 设计 用户角色分配类图

User.assignRole(role, actorDept) 要求 actorDept、当前用户 departmentId 和 role.departmentId 非空且一致，随后检查 roleIds 中不存在该角色，再把角色编号加入集合。跨部门抛出 ForbiddenException，重复分配抛出 ConflictException。应用服务在领域校验成功后持久化本次关系变化。

角色权限配置由角色用例校验所属部门和权限存在性，再通过端口维护 role_permission。此处按单次关联操作划分事务。用户、角色、部门、系统与权限的单项资料维护保持相同 API 和字段白名单。

4.3.3 共同契约与配置装配

责任	结构化实现	DDD 实现
认证	StructuredAuthService 校验账号数据与登录权限。	DddAuthService 编排凭据校验及登录权限读取。
角色分配	StructuredUserRoleService 执行校验顺序并写关联。	DddUserRoleService 加载 User、Role，调用领域行为并写关联。
角色权限	事务脚本检查本部门角色、权限存在性并写关系。	应用服务校验本部门角色与权限存在性，通过端口保存单条关系变化。
事务	事务脚本公开用例方法。	应用服务公开用例方法。
持久化	共享端口与 JPA 适配器。	共享端口与 JPA 适配器。
HTTP 契约	共享 Controller、DTO、VO、异常映射。	相同契约。

所有用例接口放在 service.port 对应模块，Command 与 Result 为普通业务数据。UserStore 等端口提供数据读写能力，接口不携带 JPA Entity 或 Spring MVC 类型。控制器按 auth、user、department、system、permission、role、user-role、role-permission 资源划分。

```
app:
  backend-strategy: structured
```

配置值为 structured 或 ddd，默认 structured。配置类以 @ConditionalOnProperty 注册对应服务，每个用例接口在启动后恰有一个服务 Bean；值非法时启动失败。服务内部按用例执行，选型在启动装配阶段完成。

4.3.4 登录与会话详细设计

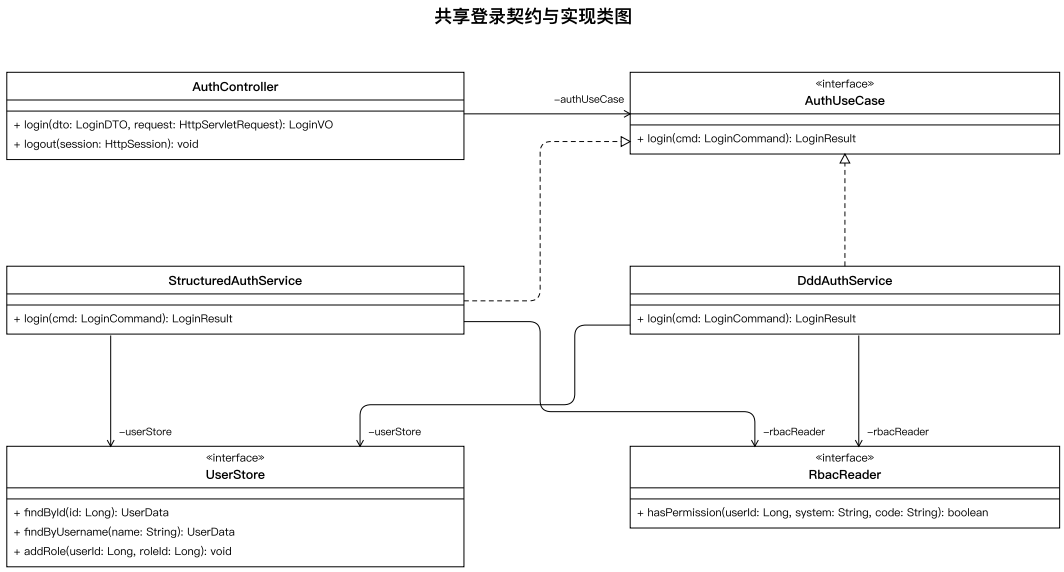


图 9. 共享登录契约与实现类图

```
{
 "username": "zhangsan",
 "password": "13800138000",
 "systems": ["rbac"]
}
```

Controller 将唯一 systems 元素映射为 LoginCommand.systemKey。服务按用户名查找用户，比较输入 password 与 app_user.phone，随后检查系统 login 权限。成功返回 LoginResult(userId, systemKey)。Controller 调用 getSession 和 changeSessionId，保存身份并返回 LoginVO。

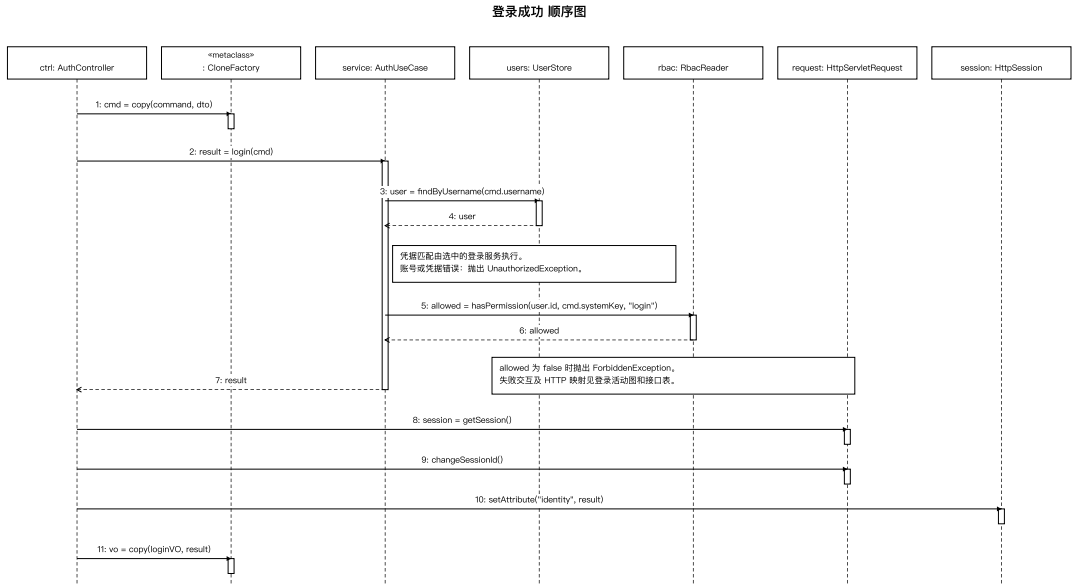


图 10. 登录成功 顺序图

登录失败清理先前身份，统一返回错误；账号不存在与手机号错误均为 401。目标系统不匹配或缺少 login 权限返回 403。失败路径见登录活动图。退出销毁会话，重复退出返回 204。

Session 的业务身份保存 userId 和 systemKey。框架维护会话及 CSRF 数据。后续请求读取当前用户和当前权限，用户删除后返回 401，目标系统 login 权限撤销后返回 403。每次成功登录替换本次目标系统；用户需要切换系统时重新提交登录资料。

4.3.5 角色分配详细设计

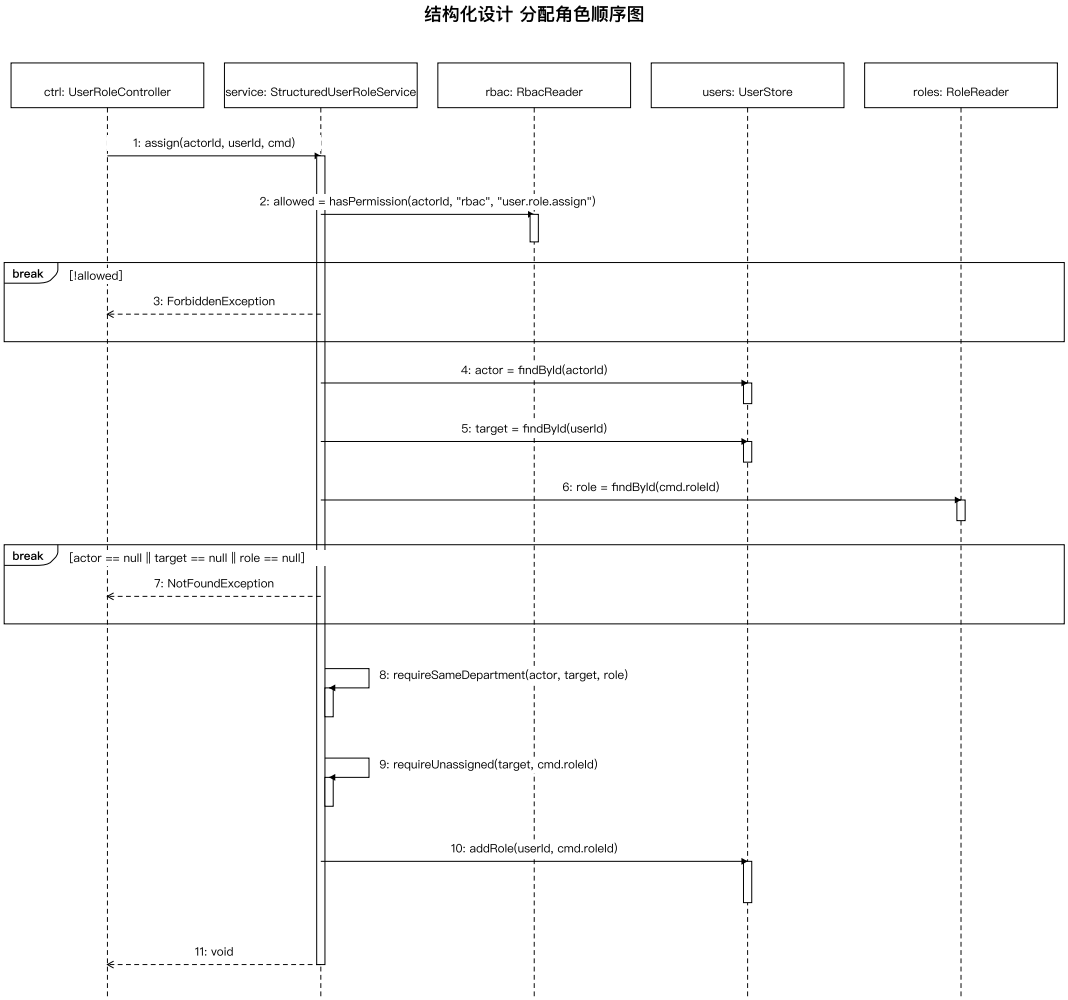


图 11. 结构化设计 分配角色顺序图

结构化版依次调用 RbacReader.hasPermission、UserStore.findById、RoleReader.findById 和内部校验方法，再调用 UserStore.addRole。方法正常返回前事务提交；异常向上抛出，由 Controller 异常处理器映射。

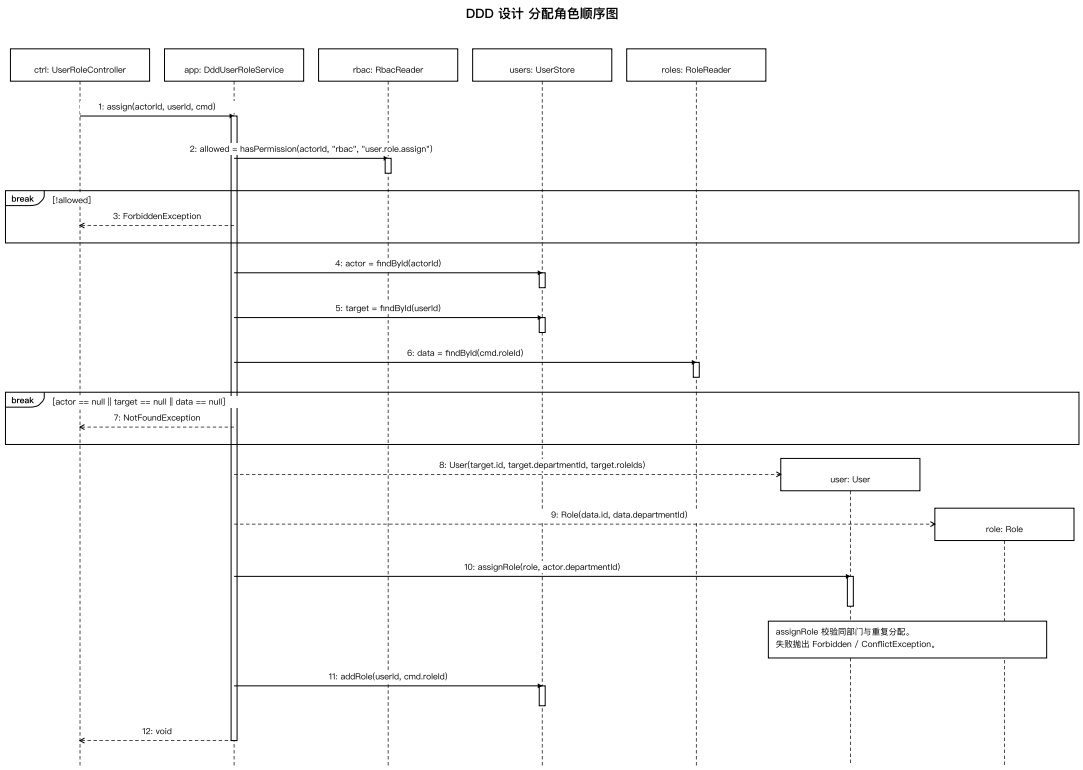


图 12. DDD 设计 分配角色顺序图

DDD 版读取相同数据，以构造消息建立 User 与 Role 对象，调用 User.assignRole，再持久化本次分配。类图、顺序图和接口使用相同方法名。两图中的 break 表示失败时终止该用例后续交互；内部规则异常沿调用链返回并回滚事务。

4.3.6 当前权限判断

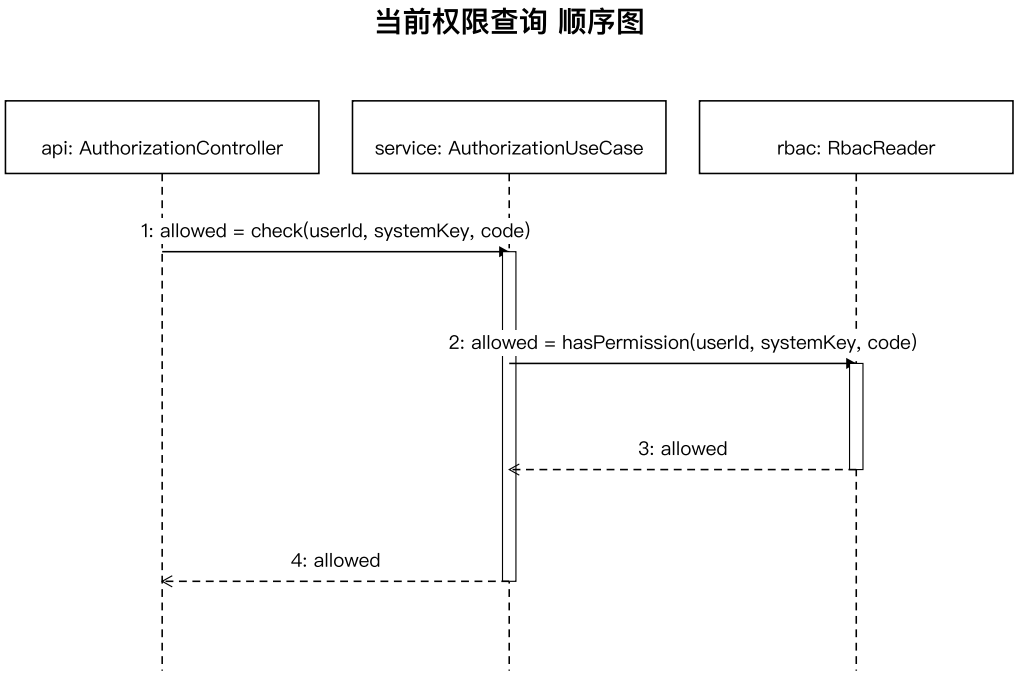


图 13. 当前权限查询 顺序图

RbacReader.hasPermission 以 userId、systemKey、code 作为查询条件，执行 EXISTS 关系查询。逻辑如下，参数通过预编译绑定：

```
SELECT EXISTS (
  SELECT 1
  FROM user_role ur
  JOIN role_permission rp ON rp.role_id = ur.role_id
  JOIN permission p ON p.id = rp.permission_id
  JOIN business_system s ON s.id = p.system_id
  WHERE ur.user_id = :userId
    AND s.system_key = :systemKey
    AND p.code = :code
);
```

平台管理操作先确认会话目标系统为 rbac、账号仍存在并具有 rbac 的 login 权限，再检查对应操作权限及资源范围。业务系统查询目标系统从 Session 取得，查询结果采用当前数据库关系。撤销一个角色后，用户仍可能通过其他角色拥有相同权限。

4.3.7 对象拷贝与运行日志

CloneFactory 依赖使用老师提供的 cn.edu.xmu:clonefactory:0.0.1-SNAPSHOT，并在 Maven 编译插件中配置注解处理器路径。使用 @CopyFrom、@CopyTo 及字段排除注解声明转换，编译生成 cn.edu.xmu.clonefactory.util.CloneFactory。

对象转换点为请求 DTO 至 Command、Result 至 VO、持久化 PO 至共享数据。id、departmentId 和授权关系由专用操作设置。领域聚合通过构造和行为维护规则，边界数据拷贝使用生成代码。

可执行层	日志内容	级别
API	请求方法、路由模板、结果和耗时。	正常 DEBUG；失败按类型记录。
结构化服务 / DDD 应用服务	用例、操作者编号、目标编号和业务结果。	正常 DEBUG；规则拒绝 WARN。
DDD 领域行为	规则结果由应用服务统一记录。	按业务结果记录，领域代码保持框架无关。
Infrastructure	持久化操作名称、耗时及失败类型。	正常 DEBUG；不可恢复异常 ERROR。

日志通过 SLF4J 调用，Logback 输出控制台与滚动文件，同一异常的完整堆栈在统一边界记录一次。输入凭据、完整手机号、Cookie、Session ID 和 CSRF 凭据从日志中排除。接口声明和数据类无需日志方法。

4.4 接口与输入设计

4.4.1 公共约定

API 前缀为 /api，交换 JSON。路径编号为正整数；列表参数 page 从 0 开始，size 默认 20，最大 100。列表结果包含 items、page、size 和 total；空列表返回 200。

Controller 使用 @Valid 与约束注解校验长度、必填项、正整数及数组大小，嵌套对象使用级联校验。未通过输入校验的请求返回 400。DTO 按创建、资料修改和授权分别定义，未声明字段返回 400。

用户名长度为 1–64，姓名与部门、角色、系统、权限名称为 1–100；文本先去除首尾空白，再校验非空。手机号采用中国大陆 11 位数字格式；本版 password 使用同样格式。systemKey 长度为 1–64，允许小写字母、数字和连字符；code 长度为 1–100，允许小写字母、数字、点、冒号和连字符。比较规则与数据库区分大小写的配置一致。

用户名、手机号和系统标识严格匹配。password 不执行静默截断或数值转换。白名单如下：

输入对象	接收字段	固定或推导字段
LoginDTO	username、password、systems	systemKey 从唯一数组元素取得。
CreateUserDTO	username、name、phone	id 生成，departmentId 取操作者部门。
UpdateUserDTO / UpdateMeDTO	name、phone	id、username、departmentId 固定。
CreateDepartmentDTO	name、parentId	id 生成。
RenameDepartmentDTO	name	parentId 固定。
CreateSystemDTO	systemKey、name	id 生成。
RenameSystemDTO	name	systemKey 固定。
CreatePermissionDTO	code、name	systemId 来自路径。
RenamePermissionDTO	name	systemId、code 固定。
CreateRoleDTO / RenameRoleDTO	name	departmentId 取操作者部门。
AssignRoleDTO	roleId	userId 来自路径，actorId 来自会话。

PATCH 使用专门 DTO，只更新出现且有效的白名单字段。传入 null、空对象或空白名称返回 400。修改本人手机号后，后续重新登录使用新手机号，当前会话继续有效。

4.4.2 认证与鉴权接口

方法	路径	结果
GET	/auth/csrf	200，返回框架 CSRF 凭据和请求头名称。
POST	/auth/login	200，返回 userId、systemKey 并更新会话 Cookie。
GET	/auth/me	200，返回本人编号、用户名、姓名、部门。
PATCH	/auth/me	204，修改本人姓名、手机号。
POST	/auth/logout	204，销毁会话。
GET	/auth/permissions/{code}	200，返回 allowed 布尔值。

路径均承接 /api 前缀。客户端先取得 CSRF 凭据，后续写请求提交对应请求头。登录和退出也校验 CSRF；登录失败与退出后客户端重新获取凭据。

4.4.3 基础数据与授权接口

方法	路径	成功	权限
GET	/users；/users/{id}	200	user.view
POST	/users	201，含 Location	user.create
PATCH	/users/{id}	204	user.edit
DELETE	/users/{id}	204	user.delete
GET / POST	/departments	200 / 201	department.manage
PATCH / DELETE	/departments/{id}	204	department.manage
GET / POST	/systems	200 / 201	system.manage
PATCH / DELETE	/systems/{id}	204	system.manage
GET / POST	/systems/{id}/permissions	200 / 201	permission.manage
PATCH / DELETE	/permissions/{id}	204	permission.manage
GET / POST	/roles	200 / 201	role.manage
GET	/roles/{id}	200	role.manage
PATCH / DELETE	/roles/{id}	204	role.manage
GET	/roles/{id}/permissions	200	role.manage
PUT / DELETE	/roles/{id}/permissions/{permissionId}	204	role.manage
GET	/users/{id}/roles	200	user.role.assign
POST	/users/{id}/roles	201，含 Location	user.role.assign
DELETE	/users/{id}/roles/{roleId}	204	user.role.assign

用户与角色列表自动限定本部门，详情和修改同样检查部门。无部门的操作者执行这些管理操作返回 403。部门树与系统目录接口按各自操作权限访问。角色权限 PUT 为幂等授予，重复授予返回 204；角色分配 POST 重复时返回 409。关联 DELETE 在实体存在而关联已撤销时返回 204。

4.4.4 错误与异常映射

HTTP	业务码	含义
400	INVALID_ARGUMENT	参数格式、空对象、受保护字段或数组数量错误。
401	UNAUTHENTICATED	凭据错误、Session 无效或账号已删除。
403	FORBIDDEN	系统登录权限、操作权限、部门边界或 CSRF 校验失败。
404	NOT_FOUND	已具备操作资格后查询的目标资源不存在。
409	CONFLICT	唯一约束、重复分配或删除引用冲突。
500	INTERNAL_ERROR	未预期的服务错误，事务回滚。
503	SERVICE_UNAVAILABLE	数据库连接或依赖不可用。

{"code":"FORBIDDEN","message":"无操作权限"}

错误响应使用稳定业务码和可读信息。数据库异常按约束名称及异常类型分类，返回信息排除 SQL、堆栈和内部连接资料。业务系统只有收到明确的 allowed=true 才执行受控操作。

5 性能需求

5.1 数据精确度

实体编号使用 BIGINT，在前端按字符串处理以保留完整精度；API 中的 Long 编号序列化为十进制字符串，输入路径及 roleId 接受可解析为正 Long 的字符串。分页总数为整数，权限判断返回布尔值。手机号按字符串保存，禁止数值化。

同一时刻有效权限为当前各角色权限的并集。撤销操作提交后发起的新鉴权请求读取已提交的新关系；已经执行中的请求按其事务可见性完成。

5.2 时间特性

课程演示的性能基线以单实例、本地或同局域网 MySQL、分页 size=20 为测量条件。登录、列表、授权和鉴权分别记录请求数、平均耗时、P95 和错误数。验收先核对授权正确性及响应是否完整，再依据实际硬件记录耗时。

本版采用同步数据库查询和有界分页。针对关系查询检查执行计划和索引使用情况。性能报告注明数据规模、硬件、运行配置及两套实现的测量结果；测量结果随测试报告归档。

5.3 适应性

两套实现使用同一份接口契约与初始化数据。启动时可通过 app.backend-strategy 切换，测试在两种配置下重复执行。数据库约束与对象拷贝代码随构建检查，避免配置切换改变业务语义。

6 运行需求

6.1 软件接口与部署

浏览器通过同源 HTTPS 入口访问前端和 /api。开发时可使用本地 HTTP，正式演示环境为 Cookie 设置 HttpOnly、SameSite=Lax，并在 HTTPS 下启用 Secure。服务依赖 MySQL；Session 存在应用进程中，应用重启后用户重新登录。

配置项	用途
spring.datasource.url / username / password	数据库连接；凭据由环境变量注入。
app.backend-strategy	structured 或 ddd。
server.servlet.session.timeout	会话空闲超时；初始配置 30 分钟。
logging.config	加载 logback-spring.xml。
logging.level	区分演示信息和排错信息。

会话超时 30 分钟为本版初始运行参数，可由配置调整。应用以单实例演示，跨系统浏览器免登录不属于本版契约。

6.2 构建与启动

1. 从老师 spring-fundamentals 仓库构建并安装 CloneFactory 模块及其依赖。
2. 在项目 POM 中声明 CloneFactory 与 Lombok 注解处理器，执行编译，检查生成的拷贝代码。
3. 在独立空数据库执行 sql/schema.sql 和演示初始化脚本。
4. 配置数据库连接和 app.backend-strategy，启动应用。
5. 使用初始化管理用户登录，检查基础数据与授权配置。
6. 分别以 structured 和 ddd 配置执行同一组契约和业务测试。

6.3 故障处理

故障	处理
输入或业务规则失败	返回相应 4xx，修改事务回滚。
唯一键或引用冲突	返回 409，页面提示刷新当前数据后处理。
数据库连接失败	返回 503，日志记录异常类型，业务系统拒绝受控操作。
未预期异常	统一返回 500，边界记录堆栈并隐藏内部错误资料。
会话过期或应用重启	返回 401，客户端进入登录页。
非法实现配置	启动失败，输出配置项名称及允许值。

6.4 图文与构建产物

AsciiDoc 为说明书正文源文件，PDF 从该源文件和本目录图片生成。UML 图以 StarUML 原生模型保存，陈氏图与表关系图保留可编辑图元及 SVG。导出脚本保留图形的黑白符号、实际目录页码、页眉和页码。

所有生成文件放在本重做目录，旧版设计书保留为排版参考。文档的 API、数据表和类名按照本基线核对，修改设计时同步更新对应图和测试条件。

7 其它需求

7.1 可用性

后台按用户、部门、角色、权限和系统组织页面。登录表单使用用户名、手机号和目标系统；权限拒绝显示具体操作失败结果。角色选择列表限定本部门，资料编辑只显示允许修改的字段。

删除操作提示目标及引用冲突，提交成功后刷新列表。角色分配与角色权限配置显示现有关系，方便管理用户核对授权结果。

7.2 权限隔离与安全

所有平台管理写请求依次校验 Session、CSRF、操作权限和数据范围；操作者编号从服务端身份读取。客户端隐藏按钮用于交互提示，后端执行相同权限检查。

手机号承担登录凭据的方案适用于课程演示。用户查询仅向具备相应权限和部门范围的管理用户返回所需资料，运行日志屏蔽凭据。部署使用 HTTPS，数据库账号按应用所需权限配置。

角色与权限变更由专用用例处理，普通资料修改保持字段白名单。JPA Entity 保持在基础设施内，响应返回 VO，防止主键、部门或关联集合通过通用更新被改写。

7.3 功能验收

下表为待实现系统的验收场景。每项分别在 structured 和 ddd 两种配置下执行，记录 HTTP 响应、数据库结果和日志，预期结果一致。

编号	操作与条件	预期
ACC-01	正确用户名、手机号，且有目标系统 login。	200，Session 标识更新，返回正确身份。
ACC-02	用户名不存在或手机号错误。	401，响应不区分两种原因，旧身份清理。
ACC-03	无系统 login，或 systems 包含多个元素。	分别为 403、400。
ACC-04	退出后复用原 Cookie。	退出 204，后续受保护请求 401。
ACC-05	拥有角色分配权限，同部门且尚未分配。	201，仅新增一条 user_role。
ACC-06	跨部门分配或无操作权限。	403，数据库无新增关联。
ACC-07	重复分配及两个并发重复请求。	已存在时 409；并发最多新增一次。

编号	操作与条件	预期
ACC-08	多个角色包含相同权限，撤销其中一个角色。	剩余角色仍提供权限时 allowed=true。
ACC-09	撤销最后一个相关权限并提交后重新查询。	allowed=false；撤销 login 后受保护请求 403。
ACC-10	普通资料请求包含 id、departmentId 或授权字段。	400，目标资料和授权保持原值。
ACC-11	删除用户。	用户及 user_role 同事务删除；旧会话后续 401。
ACC-12	删除仍有子部门、成员、角色或权限引用的对象。	409，关联完整。
ACC-13	缺少或伪造 CSRF 凭据的写请求。	403，服务修改未执行。
ACC-14	修改本人资料、查询其他部门用户。	本人白名单修改成功，跨部门请求 403。
ACC-15	大小写不同的用户名、系统标识或权限编码。	按已定义的区分大小写规则匹配。
ACC-16	数据库不可用。	503；外部系统拒绝执行受控操作。
ACC-17	分别启动两套服务及非法配置。	各有效配置只有一套用例 Bean；非法值启动失败。
ACC-18	编译 CloneFactory 并检查各层日志。	生成边界拷贝代码；日志含层次与结果，排除敏感值。

7.4 文档与模型验收

图中类的方法签名与顺序图消息对应，成员引用使用关联，临时使用使用依赖，接口实现使用虚线空心三角。顺序图的构造消息与生命线起点对应，执行说明覆盖调用区间。图形在 StarUML 中可编辑，导出预览与模型内容一致。

数据库表关系图对应 sql/schema.sql 的七张表、八条外键及唯一约束。PDF 使用清晰的图题、表头、正文、目录和页码，AsciiDoc 与 PDF 内容一致。业务验收结果、性能测量和构建版本在实现阶段随测试报告归档。